

Имовина, границе поверења и threat modeling

Идентификација имовине, токова података и граница поверења

Имовина и границе поверења

Анализа претњи полази од вредне имовине, токова података, граница поверења и последица могућег нарушавања.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Безбедносна одлука полази од вредне имовине, тока података и граница поверења. На тој основи тим идентификује релевантну претњу и бира контролу примерену конкретном ризику.

ЗНАЧАЈ

Значај за безбедност система

Моделовање претњи повезује техничку структуру система са пословним последицама и омогућава рану проверу безбедносних претпоставки.

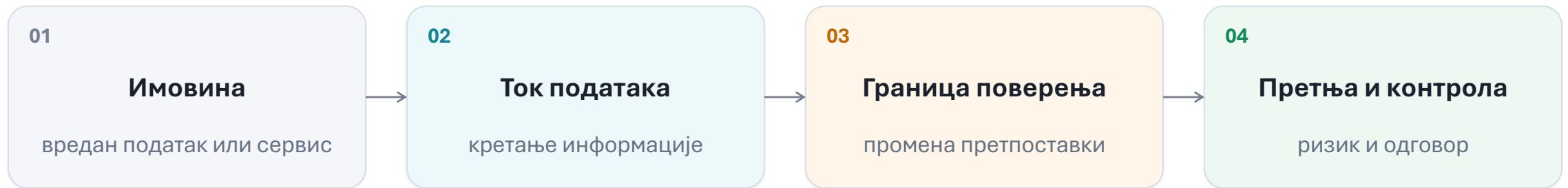
КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

ОСНОВНИ ПОЈМОВИ

Имовина, ток података, граница поверења и претња одређују обим анализе и избор контроле.



ЗАКЉУЧАК

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.

Имовина

вредан податак или сервис

01

Имовина има власника, значај и животни циклус.

Питање: који улаз покреће ову одлуку?

02

Имовина обухвата базу података, налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе.

Питање: која граница мора бити видљива?

03

Критичност имовине одређује колико брзо се реагује и колико је доказа потребно.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

Ток података

кретање информације

01

Интеграција спољне компоненте не представља основ за доделу поверења.

Питање: који улаз покреће ову одлуку?

02

Граница поверења може бити API позив, ред порука, административни интерфејс или извоз у датотеку.

Питање: која граница мора бити видљива?

03

Ток података открива места на којима информација може бити измењена, изгубљена или погрешно изложена.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

Граница поверења

промена претпоставки

01

Претња постаје корисна када води до захтева, контроле и начина провере.

Питање: који улаз покреће ову одлуку?

02

Модел претњи обухвата ограничен број реалних сценарија, одговарајуће контроле и начине њихове провере.

Питање: која граница мора бити видљива?

03

Претња добија приоритет према утицају, вероватноћи и реалним постојећим контролама.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

Претња и контрола

ризик и одговор

01

Критичност имовине одређује колико брзо се реагује и колико је доказа потребно.

Питање: који улаз покреће ову одлуку?

02

Ток података открива места на којима информација може бити измењена, изгубљена или погрешно изложена.

Питање: која граница мора бити видљива?

03

Претња добија приоритет према утицају, вероватноћи и реалним постојећим контролама.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

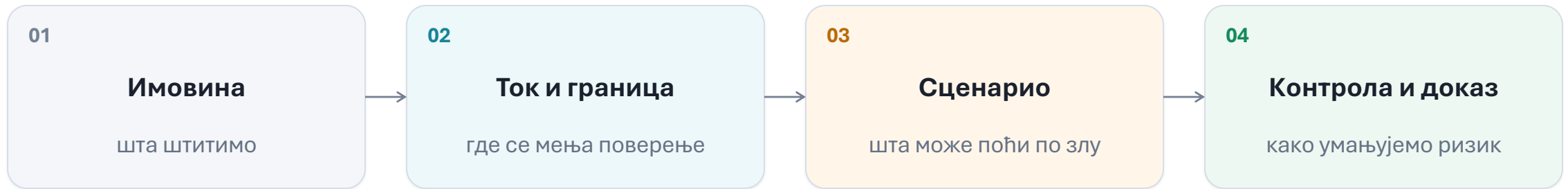
Имовина, рањивост и претња

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Појам	Значење	Питање за анализу
Имовина	Оно чија вредност захтева заштиту.	Шта губимо ако је угрожена?
Рањивост	Слабост коју је могуће искористити.	Где систем нема довољну заштиту?
Претња	Могући узрок нежељеног исхода.	Ко или шта може активирати слабост?
Ризик	Комбинација вероватноће и последице.	Шта прво треба умањити?

Модел threat модела

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Читање архитектонске скице кроз безбедност

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Читање архитектонске скице кроз безбедност

Архитектонска скица добија безбедносну вредност када се преко компоненти уцртају подаци, идентитети и границе поверења. Није потребно цртати сваку класу. Довољно је показати делове кроз које пролази вредна информација и одлуке које мењају њен статус.

01

Означити улазе које контролише корисник или спољашњи сервис.

02

Означити место где се идентитет или дозвола поново проверавају.

03

Означити складишта, кључеве и интеграције које мењају последицу инцидента.

04

Уз сваку границу записати једну реалну претпоставку која може бити погрешна.

Модел пре контроле

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

Имовина има власника, значај и животни циклус.

Јасно правило

02

Интеграција спољне компоненте не представља основ за доделу поверења.

Проверљива примена

03

Претња постаје корисна када води до захтева, контроле и начина провере.

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Архитектурни цртеж постаје радни алат када уз сваку важну границу наведе податке, актере и претпоставке. Тим затим бира мали број реалних мисусе сценарија и проверава их тестом или прегледом дизајна.

01

Дефинисана одлука и њена граница.

02

Серверска имплементација провере.

03

Позитиван и негативан доказ.

Случај: извоз из интерног система

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: извоз из интерног система

Интерни сервис припрема извоз осетљивих података за други систем. Тим га доживљава као безбедан јер је сервис „унутра“, али сам прелазак података у други систем мења претпоставке. Потребно је знати који податак путује, ко прима податак, шта може поћи по злу и како систем спречава или бар открива нежељен исход.

01

Имовина обухвата базу података, налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе.

02

Граница поверења може бити API позив, ред порука, административни интерфејс или извоз у датотеку.

03

Модел претњи обухвата ограничен број реалних сценарија, одговарајуће контроле и начине њихове провере.

Граница поверења тражи експлицитну проверу

Провера границе поверења претходи обради података који стижу из спољног контекста.

```
1 public Result<Payment> Create(ExternalRequest input)
2 {
3     var command = validator.ParseAndValidate(input);
4     if (!trustPolicy.Accepts(command.Source, command.Signature))
5         return Result.Deny("untrusted_source");
6     if (command.Amount > limits.For(command.AccountId))
7         return Result.Deny("limit_exceeded");
8     return payments.Create(command);
9 }
```

ТУМАЧЕЊЕ

Спољни улаз се прво валидира и доказује, па тек онда сме да покрене пословну промену.

БЕЗБЕДНОСНА ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Тест доказује да претња не стиже до имовине

Тест показује да спољни улаз не прелази границу поверења без предвиђене провере.

```
1 [Fact]
2 public void Untrusted_input_stops_at_the_boundary()
3 {
4     var request = ExternalRequest.WithInvalidSignature();
5
6     var result = service.Create(request);
7
8     result.Reason.Should().Be("untrusted_source");
9     repository.Writes.Should().Be(0);
10 }
```

ДОКАЗ

Очекивани исход обухвата одбијање захтева и одсуство уписа у заштићено стање.

ОЧЕКИВАНИ ИСХОД

Тест мења једну чињеницу и очекује јасан, стабилан разлог одбијања.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

```
1 {  
2   "asset": "payment-ledger",  
3   "trustBoundary": "public-api",  
4   "threat": "forged-command",  
5   "control": "signature-validation",  
6   "test": "reject-invalid-signature",  
7   "residualRisk": "stolen-valid-key"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, токен, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

Инвентар који постоји само ради евиденције, без власништва и значаја.

Нема јасног власника одлуке.

02

Општи каталог претњи који није повезан са стварним системом.

Не постоји негативан сценарио.

03

Контрола изабрана пре разумевања ризика који треба да смањи.

Доказ не показује стварни исход.

Одржавање модела претњи

Модел се ажурира када се промене имовина, ток података, граница поверења или претпоставке система.

ОБРАЗЛОЖЕЊЕ

Одржавање модела претњи

Модел претњи ажурира се када систем добије нови улаз, интеграцију, начин чувања података или привилеговану радњу. Значајна архитектонска промена захтева поновну проверу постојећих претпоставки.

01

Дијаграм се ажурира када ток података или граница поверења стварно промени понашање система.

02

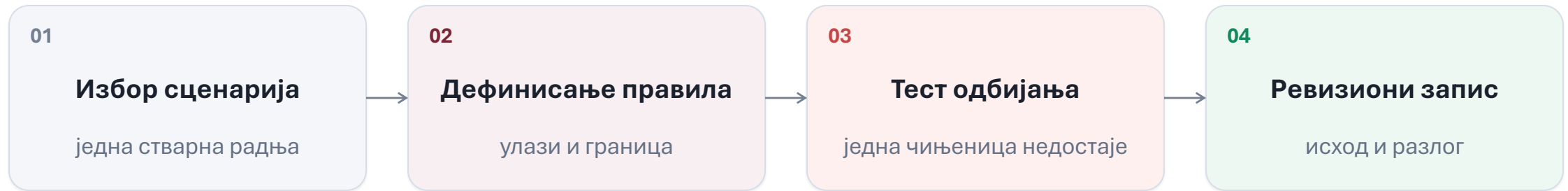
За одабрани сценарио постоји веза до контроле, теста или прегледа који га проверава.

03

Преостали ризик бележи се јасно, заједно са прихваћеним ограничењима контроле.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

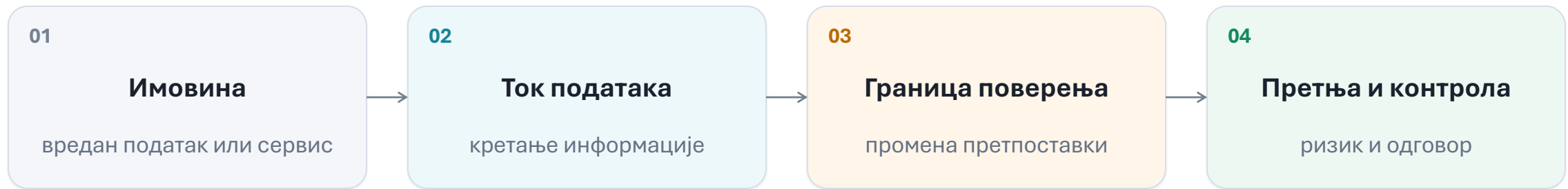


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Имовина, границе поверења и threat modeling“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.



ПИТАЊЕ ЗА ПРОВЕРУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.